

Governance, Responsible AI & Security Architecture

Scaling with control: trust as an accelerant, not a brake

Contents of this deliverable

- AI governance operating model and decision rights
- Responsible AI framework and risk tiering
- Model and agent lifecycle governance
- Security architecture for AI systems, including non-human identity
- Data governance, compliance, auditability, and FinOps controls

1. AI Governance Operating Model

Governance is designed as a two-speed system: a light-touch paved road for low-risk uses, and rigorous review concentrated where consequences are real. The failure mode to avoid is a single committee reviewing everything - it becomes a queue, teams route around it, and shadow AI wins.

Body	Composition	Mandate	Cadence
AI Executive Council	CEO or delegate, CFO, CRO, CIO/CTO, CHRO, GC, BU presidents	Owns AI strategy, risk appetite, investment envelope; final authority on Tier-1 deployments	Monthly
AI Portfolio Board	Transformation lead (chair), CoE head, Finance, BU sponsors	Funds, sequences, and kills initiatives; tracks audited benefits	Monthly
Responsible AI Review Board	Risk, Legal, Security, Data, domain experts; independent chair	Reviews Tier-1/Tier-2 systems pre-deployment and on material change; owns incident taxonomy	Weekly triage; deep reviews as scheduled
Platform & Standards Authority	CoE architecture leads + federated architects	Owns reference architecture, MCP/tooling standards, model approvals, exception process	Continuous, with 2-week exception SLA

2. Responsible AI Framework and Risk Tiering

Principles (operationalized, not poster-ware)

- **Human accountability.** Every AI system and agent has a named accountable owner; AI never owns a decision, a person does.
- **Proportionate oversight.** Control intensity scales with risk tier, aligned to EU AI Act classes and sector rules on automated decision-making.
- **Transparency.** Users and customers know when they interact with AI; consequential outputs carry provenance and, where feasible, citations.
- **Fairness with evidence.** Systems touching people (hiring, credit-like decisions, pricing) undergo bias testing pre-deployment and in production monitoring.
- **Privacy by design.** Data minimization in prompts and memory; retention TTLs; deletion requests propagate through indexes and vector stores.
- **Contestability.** Any person affected by an AI-influenced decision has a route to human review.

Risk tiers and required controls

Tier	Definition & examples	Required controls
Tier 1 - High consequence	Affects individuals' rights, money, safety, or legal position: employment decisions, credit-like determinations, autonomous customer commitments, regulated communications	RAI Board approval; documented impact assessment; bias & robustness testing; human decision rights preserved; enhanced logging; annual revalidation; Executive Council visibility

Tier	Definition & examples	Required controls
Tier 2 - Material business	Customer-facing content and service, financial-process automation, agentic actions on systems of record	Standard evaluation suite; A-level autonomy gating; owner sign-off; monitoring with alert thresholds; incident playbook
Tier 3 - Internal productivity	Drafting, summarization, search, coding assistance within governed tools	Paved-road self-service; acceptable-use policy; data-classification guardrails; sampling-based quality review

3. Model and Agent Lifecycle Governance

Stage	Governance requirement
Intake	Use case registered in central inventory with risk tier, data classes, and owner - the inventory is a regulatory expectation, not bureaucracy
Model selection	Only gateway-approved models; vendor terms verified (no training on our data without consent; IP indemnity; data residency)
Pre-deployment	Evaluation suite passed (quality, safety, bias where applicable); security review incl. prompt-injection testing for tool-connected systems; rollback plan
Deployment	Autonomy level assigned (A0-A3 per Deliverable 03); entitlements scoped least-privilege; monitoring live before traffic
Operation	Drift and quality monitoring; material change (model swap, prompt change, new tool) triggers regression evals; periodic revalidation by tier
Incident	AI incident taxonomy (hallucination-caused harm, data leakage, unauthorized action, bias event); severity-based response; RAI Board post-mortems feed policy
Retirement	Decommission checklist: entitlements revoked, memory purged per retention policy, inventory updated

4. Security Architecture for AI Systems

New threat surface, extended zero-trust

Threat	Primary controls
Prompt injection (direct & indirect via retrieved content)	Input/output filtering; privilege separation between reasoning and action; untrusted-content tagging in RAG; tool-call allowlists; injection test suites in CI
Data leakage via prompts, memory, or logs	DLP on AI gateway; PII redaction in traces; memory TTLs; egress controls on model endpoints; tenant isolation
Excessive agent privilege / unauthorized actions	Non-human identity per agent (see below); just-in-time, scoped credentials; transaction limits; anomaly detection on agent behavior
Model supply chain	Approved-model registry; provenance verification; sandboxed evaluation of new models/tools before catalog entry
Abuse & jailbreak of customer-facing AI	Safety classifiers; rate limiting; abuse monitoring; red-team program with quarterly exercises
Shadow AI	Discovery via CASB/network analytics; sanctioned alternatives that are genuinely better; graduated enforcement

Identity and access for humans and agents

- **Every agent is a first-class identity** in the IAM system - registered, credentialed (short-lived tokens, no shared secrets), and owned by a named human sponsor.
- **Entitlements are per-agent and per-tool**, expressed as scopes on MCP servers; the effective permission of an agent acting for a user is the *intersection* of agent scope and user entitlement, never the union.
- **Delegation chains are recorded**. When agent A invokes agent B, the originating human context propagates so audit can answer 'who caused this action' for every write.
- **Segregation of duties applies to agents** exactly as to people: an agent that prepares a payment cannot approve it.

5. Data Governance, Compliance, Auditability, and FinOps

- **Data governance**. Classification drives what may enter prompts, indexes, and fine-tunes; consent and purpose limitation enforced at the retrieval service; lineage from source to AI output.
- **Regulatory compliance**. Obligations register mapped to controls: EU AI Act deployer duties (inventory, transparency, human oversight, logging), privacy regimes (DPIAs for Tier-1/2, deletion propagation), sector rules on automated decisions; regulatory-change monitoring feeds quarterly control updates.
- **Auditability**. For every consequential AI action: input, retrieved context references, model + version, tool calls, output, human approvals - retained per policy and reconstructable; this is the evidence base for regulators, auditors, and internal challenge.
- **Risk management integration**. AI risks in the enterprise risk register with owners and KRIs (Deliverable 06); internal audit builds AI-assurance capability in Year 1.
- **FinOps controls**. Budget guardrails per team at the gateway; anomaly alerts on token spend; quarterly unit-economics review by the Portfolio Board so cost discipline is governed, not hoped for.